



Glitter: מחקר אבטחה

במסמך זה נתעד את כל תהליך הבדיקות של שלב א', גם את הבדיקות שהניבו פרי וגם את אלו שלא – פשוט הכל! בסיום המסמך יש סיכום של כל החולשות שנמצאו ומוגשות. יחד עם המסמך יש להגיש את קבצי ה-py של הוכחות ההיתכנות.

1. חלק א' – מחקר פרוטוקול כללי

השתמש בכלי המחקר הרגילים שלנו כדי לאסוף מאפיינים כלליים על הפרוטוקול.

Glitter	שם פרוטוקול
TCP	מעל TCP/UDP
1336	פורט
stateful, טקסטואלי	מאפייני פרוטוקול
Request_Number#{gli&&er}{field_name:field_value}##	פורמט כללי של בקשה
Response_Number#Command_Description#{gli&&er}{field_name:field_value}##	פורמט כללי של תגובה

קראו למדריך/ה לפני שאתם ממשיכים לשלב הבא!

2. חלק ב' - סיכום חולשות

יש למלא חלק זה תוך כדי מילוי של חלק ג'. אם אתם בסייקל הראשון בכיתה – **דלגו על הטבלה** ועברו לחלק ג' כעת.

חולשות שנמצאו			
הסבר על החולשה שנמצאה	כיצד תוקף יכול לנצל זאת (למה לא רוצים שדבר כזה יהיה אפשרי)	סקריפט POC מצורף	הצעה לפתרון
ביצוע לייק למזהה גליט שאינו קיים.	התנהגות לא צפויה, ביצוע לייקים לגליטים שאינם קיימים.	שלוחות 1, 1 בתפריט.	הוספת בדיקה האם מזהה הגליט קטן ממזהה הגליט האחרון שפורסם באתר.
ביצוע לייק לגליט של משתמש פרטי שאינו אחד מחבריו.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים, ביצוע לייקים לגליט של אנשים פרטיים שאינם רוצים בחברתו.	שלוחות 1, 2 בתפריט.	הוספת בדיקה האם מפרסם הגליט הוא אחד מחבריו של המשתמש, אם כך הדבר, תינתן האפשרות לבצע לייק.
ביצוע לייק תוך שניו שם המסך לשם קצר מחמש תווים או ריק.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 1, 3 בתפריט.	הוספת בדיקה האם שם המסך גדול מ-5 תווים.
ביצוע לייק תוך שניו שם המסך לשם שאינו קיים במערכת.	התנהגות לא צפויה, ביצוע לייקים על ידי משתמשים שאינם קיימים.	שלוחות 1, 3 בתפריט.	הוספת בדיקה האם שם המסך קיים במערכת.
ביצוע לייק פעמיים לגליט.	זיוף, ביצוע מספר מרובה של לייקים לגליט על ידי משתמש יחיד.	שלוחות 1, 4 בתפריט.	הוספת שדה בוליאני שאומר אם המשתמש כבר ביצע לייק לגליט זה בעבר.
הסרת לייק שנעשה על ידי משתמש אחר.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים, מחיקת לייקים של משתמשים אחרים.	שלוחות 1, 5 בתפריט.	הוספת בדיקה האם הלייק בוצע במקור על ידי אותו המשתמש (על ידי מזהה הלייק).
חשיפת מזהה הגליט בעת ביצוע לייק.	דליפת מידע, קבלת מידע אודות גליט שאינו בבעלות המשתמש.	שלוחות 1, 6 בתפריט.	הצפנת השדה בתגובה.
פרסום תגובה למזהה גליט שאינו קיים.	התנהגות לא צפויה, פרסום תגובות לגליטים שאינם קיימים.	שלוחות 2, 1 בתפריט.	הוספת בדיקה האם מזהה הגליט קטן ממספר הגליט האחרון שפורסם באתר.
פרסום תגובה לגליט של משתמש פרטי שאינו אחד מחבריו.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים, פרסום תגובות בגליט של אנשים פרטיים שאינם רוצים בחברתו.	שלוחות 2, 2 בתפריט.	הוספת בדיקה האם מפרסם הגליט הוא אחד מחבריו של המשתמש, אם כך הדבר, תינתן האפשרות לפרסם תגובה.

פרסום תגובה תוך שינוי שם המסך לשם קצר מחמש תווים או ריק.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 2, 3 בתפריט.	הוספת בדיקה האם שם המסך גדול מ-5 תווים.
פרסום תגובה תוך שינוי שם המסך לשם שאינו קיים במערכת.	התנהגות לא צפויה, פרסום תגובות על ידי משתמשים שאינם קיימים.	שלוחות 2, 3 בתפריט.	הוספת בדיקה האם שם המסך קיים במערכת.
פרסום תגובה ללא תוכן [PATCHED].	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 2, 4 בתפריט.	הוספת בדיקה האם תוכן התגובה גדול מאפס תווים.
פרסום תגובה שתוכנה ארוך מ-140 תווים.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 2, 5 בתפריט.	הוספת בדיקה האם תוכן התגובה קטן או שווה ל-140 תווים.
פרסום תגובה בזמן עבר או עתיד.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 2, 7/6 בתפריט.	הסרת השדה מהבקשה, השרת יקבע אצלו את זמן הפרסום בעת שקיבל את הבקשה, לא הלקוח.
ביצוע HTML Injection בשדה התוכן של בקשת פרסום התגובה.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 2, 8 בתפריט.	חסימת תווים מיוחדים מתוכן התגובה: '>', '<', '"', '&'. וכו'.
חשיפת מזהה הגליט בעת פרסום תגובה.	דליפת מידע, קבלת מידע אודות גליט שאינו בבעלות המשתמש.	שלוחות 2, 9 בתפריט.	הצפנת השדה בתגובה.
ביצוע וואו לגליט.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים, פיצ'ר שאינו קיים בממשק הגרפי של האתר.	שלוחה 3 בתפריט.	הוספת הפיצ'ר בממשק הגרפי של האתר או לחלופין הסרת טיפולו מהשרת.
ביצוע וואו למזהה גליט שאינו קיים.	התנהגות לא צפויה, ביצוע וואו לגליטים שאינם קיימים.	שלוחות 3, 1 בתפריט.	הוספת בדיקה האם מזהה הגליט קטן ממספר הגליט האחרון שפורסם באתר.
ביצוע וואו לגליט של משתמש פרטי שאיני אחד מחבריו.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים, ביצוע וואו לגליט של אנשים פרטיים שאינם רוצים בחברתו.	שלוחות 3, 2 בתפריט.	הוספת בדיקה האם מפרסם הגליט הוא אחד מחבריו של המשתמש, אם כך הדבר, תינתן האפשרות לבצע וואו.
ביצוע וואו תוך שינוי שם המסך לשם קצר מחמש תווים או ריק.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 3, 3 בתפריט.	הוספת בדיקה האם שם המסך גדול מ-5 תווים.

ביצוע וואו תוך שינוי שם המסך לשם שאינו קיים במערכת.	התנהגות לא צפויה, ביצוע וואו על ידי משתמשים שאינם קיימים.	שלוחות 3, 3 בתפריט.	הוספת בדיקה האם שם המסך קיים במערכת.
ביצוע וואו פעמיים לגליט.	זיוף, ביצוע מספר מרובה של וואו לגליט על ידי משתמש יחיד.	שלוחות 3, 4 בתפריט.	הוספת שדה בוליאני שאומר אם המשתמש כבר ביצע וואו לגליט זה בעבר.
הסרת וואו שנעשה על ידי משתמש אחר.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים, מחיקת וואו של משתמשים אחרים.	שלוחות 3, 5 בתפריט.	הוספת בדיקה האם הוואו בוצע במקור על ידי אותו המשתמש (על ידי מזהה הוואו).
חשיפת מזהה הגליט בעת ביצוע וואו.	דליפת מידע, קבלת מידע אודות גליט שאינו בבעלות המשתמש.	שלוחות 3, 6 בתפריט.	הצפנת השדה בתגובה.
פרסום גליט בפיד של משתמש פרטי שאינו אחד מחבריו.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים, פרסום גליטים בפיד של אנשים פרטיים שאינם רוצים בחברתו.	שלוחות 4, 1 בתפריט.	הוספת בדיקה האם בעל הפיד הוא אחד מחבריו של המשתמש, אם כך הדבר, תינתן האפשרות לפרסם גליט.
פרסום גליט תוך שינוי שם המסך לשם קצר מחמש תווים או ריק בפיד של משתמש אחר.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 4, 2 בתפריט.	הוספת בדיקה האם שם המסך גדול מ-5 תווים.
פרסום גליט תוך שינוי שם המסך לשם שאינו קיים במערכת בפיד של משתמש אחר.	התנהגות לא צפויה, פרסום גליטים על ידי משתמשים שאינם קיימים.	שלוחות 4, 2 בתפריט.	הוספת בדיקה האם שם המסך קיים במערכת.
פרסום גליט ללא תוכן [PATCHED].	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 4, 3 בתפריט.	הוספת בדיקה האם תוכן הגליט גדול מאפס תווים.
פרסום גליט שתוכנו ארוך מ-140 תווים.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 4, 4 בתפריט.	הוספת בדיקה האם תוכן הגליט קטן או שווה ל-140 תווים.
פרסום גליט בזמן עבר או עתיד.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 4, 5/6 בתפריט.	הסרת השדה מהבקשה, השרת יקבע אצלו את זמן הפרסום בעת שקיבל את הבקשה, לא הלקוח.
ביצוע HTML Injection בשדה התוכן של בקשת פרסום גליט.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 4, 7 בתפריט.	חסימת תווים מיוחדים מתוכן הגליט: '>', '<', '/' וכל.
פרסום גליט תוך שינוי האווטאר לאווטאר שונה מהמוגדר במשתמש.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים, פיצ'ר שאינו קיים בממשק הגרפי של האתר.	שלוחות 4, 8 בתפריט.	הוספת הפיצ'ר בממשק הגרפי של האתר או לחלופין הסרת השדה מהבקשה.

פרסום גליט תוך שינוי צבע הפונט.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים, פיצ'ר שאינו קיים בממשק הגרפי של האתר.	שלוחות 4, 9 בתפריט.	הוספת הפיצ'ר בממשק הגרפי של האתר או לחלופין הסרת השדה מהבקשה.
פרסום גליט תוך שינוי צבע הרקע לצבע שאינו קיים במערכת.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים, צבע שאינו קיים בממשק הגרפי של האתר.	שלוחות 4, 10 בתפריט.	הוספת בדיקה האם צבע הרקע שהוכנס תואם לאחת האופציות בממשק הגרפי של האתר.
ביצוע הרשמה עם קוד הרשמה קצר מ-5 תווים.	התנהגות לא צפויה.	שלוחות 5, 1 בתפריט.	הוספת בדיקה האם קוד ההרשמה קצר מ-5 תווים.
ביצוע הרשמה עם שם מסך קצר מ-5 תווים [PATCHED]	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 5, 2 בתפריט.	הוספת בדיקה האם שם המסך קצר מ-5 תווים.
ביצוע הרשמה עם שם משתמש קצר מ-5 תווים [PATCHED]	התנהגות לא צפויה.	שלוחות 5, 3 בתפריט.	הוספת בדיקה האם שם המשתמש קצר מ-5 תווים.
ביצוע הרשמה עם כתובת מייל ריקה [PATCHED]	התנהגות לא צפויה.	שלוחות 5, 4 בתפריט.	הוספת בדיקה שדה כתובת המייל חוקי.
ביצוע חיפוש ריק.	התנהגות לא צפויה.	שלוחות 6, 1 בתפריט.	הוספת בדיקה האם המחרוזת לחיפוש מכילה תו אחד ומעלה.
חשיפת מזהה של משתמש וכתובת המייל של משתמש בעת ביצוע חיפוש לפי שם המסך של המשתמש.	דליפת מידע, קבלת מידע אודות משתמשים אחרים.	שלוחות 6, 2 בתפריט.	הסתרת השדות מהתגובה.
עדכון שם המסך לשם קצר מ-5 תווים [PATCHED]	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 7, 1 בתפריט.	הוספת בדיקה האם שם המסך גדול מ-5 תווים.
חשיפת שם משתמש של משתמש אחר בעת ניסיון עדכון הגדרות לפי מזהה המשתמש.	דליפת מידע, קבלת מידע אודות משתמשים אחרים.	שלוחות 7, 2 בתפריט.	הסתרת השדה מהתגובה.
חשיפת סיכום הביקורת של סיסמת משתמש: חשיפת מזהה המשתמש בעת	דליפת מידע, קבלת מידע אודות משתמשים אחרים.	שלוחות 8, 1 בתפריט.	הסתרת השדות מהתגובות.

			ביצוע חיפוש לפי שם המסך של המשתמש <- חשיפת שם המשתמש בעת ניסיון עדכון הגדרות לפי מזהה המשתמש <- חשיפת סיכום הביקורת של המשתמש בעת ניסיון התחברות עם שם המשתמש וסיסמא שגויה <- חישוב וחיסור סיכום הביקורת של שם המשתמש מסיכום הביקורת הכולל של המשתמש.
--	--	--	---

3. חלק ג' – מחקר נק' כניסה

השתמשו בטבלה הבאה בתור תבנית – שכפלו אותה עבור כל נק' כניסה שאתם חוקרים.

נק' כניסה היא בקשה ספציפית בפרוטוקול.

זכרו לשאול את עצמכם את השאלות הבאות:

- איזו דרך יש לתקוף כל פרמטר בפני עצמו?

- איזו דרך יש שעצם הבקשה תהיה תקיפה?

יש לשכפל את 2 הטבלאות האלה עבור כל נק' כניסה

מחקר נק' כניסה

710		מספר הבקשה
לייק		שם הבקשה בעברית
710#{gli&&er}{ "glit_id":164804,"user_id":68793,"user_screen_name":"lorem_ipsum","id":-1}##		דוגמא אמיתית
ביצוע לייק לגליט		תפקיד הבקשה
הסבר	שם	תיאור פרמטרים
מזהה הגליט	glit_id	
מזהה המשתמש	user_id	
שם המסך של המשתמש	user_screen_name	
מזהה הלייק	id	
715#Like publish approved{gli&&er}{ "glit_id":164804,"user_id":68793,"user_screen_name":"lorem_ipsum","id":2150319,"date":"2026-09-25T21:07:18.020Z"}##		דוגמא אמיתית לתגובה

תרחישי תקיפה לנק' כניסה

תרחישים הקשורים לפרמטר ספציפי או לעצם הבקשה

החולשה	סוג החולשה (STRIDE)	הצליח / לא הצליח
ביצוע לייק למזהה גליט שאינו קיים.	Tampring	הצליח
ביצוע לייק לגליט של משתמש פרטי שאינו אחד מחבריו.	Tampring	הצליח
ביצוע לייק תוך שינוי שם המסך לשם קצר מחמש תווים או ריק.	Tampring	הצליח
ביצוע לייק תוך שינוי שם המסך לשם שאינו קיים במערכת.	Tampring	הצליח
ביצוע לייק פעמיים לגליט.	Other	הצליח
חשיפת מזהה הגליט בעת ביצוע לייק.	Information Disclosure	הצליח
ביצוע לייק תוך שינוי מזהה המשתמש למזהה של משתמש אחר.	Spoofing	לא הצליח
ביצוע לייק תוך שינוי מזהה המשתמש למזהה משתמש שאינו קיים.	Spoofing	לא הצליח

מחקר נק' כניסה

מספר הבקשה	650														
שם הבקשה בעברית	תגובה														
דוגמא אמיתית	650#{gli&&er}{"glit_id":164807,"user_id":68793,"user_screen_name":"lorem_ipsum","id":-1,"content":"lorem_ipsum","date":"2026-09-26T00:09:22.109197Z"}##														
תפקיד הבקשה	פרסום תגובה לגליט														
תיאור פרמטרים	<table> <tr> <th>שם</th><th>הסבר</th></tr> <tr> <td>glit_id</td><td>מזהה הגליט</td></tr> <tr> <td>user_id</td><td>מזהה המשתמש</td></tr> <tr> <td>user_screen_name</td><td>שם המסך של המשתמש</td></tr> <tr> <td>id</td><td>מזהה התגובה</td></tr> <tr> <td>content</td><td>תוכן התגובה</td></tr> <tr> <td>date</td><td>זמן פרסום התגובה</td></tr> </table>	שם	הסבר	glit_id	מזהה הגליט	user_id	מזהה המשתמש	user_screen_name	שם המסך של המשתמש	id	מזהה התגובה	content	תוכן התגובה	date	זמן פרסום התגובה
שם	הסבר														
glit_id	מזהה הגליט														
user_id	מזהה המשתמש														
user_screen_name	שם המסך של המשתמש														
id	מזהה התגובה														
content	תוכן התגובה														
date	זמן פרסום התגובה														
דוגמא אמיתית לתגובה	Comment publish 655# approved{gli&&er}{"glit_id":164807,"user_id":68793,"user_screen_name":"lorem_ipsum","id"##:65257,"date":"2026-09-26T00:09:22.109197Z","content":"lorem_ipsum"}														

תרחישי תקיפה לנק' כניסה

תרחישים הקשורים לפרמטר ספציפי או לעצם הבקשה

החולשה	סוג החולשה (STRIDE)	הצליח / לא הצליח
פרסום תגובה למזהה גליט שאינו קיים.	Tampring	הצליח
פרסום תגובה לגליט של משתמש פרטי שאיני אחד מחבריו.	Tampring	הצליח
פרסום תגובה תוך שינוי שם המסך לשם קצר מחמש תווים או ריק.	Tampring	הצליח
פרסום תגובה תוך שינוי שם המסך לשם שאינו קיים במערכת.	Tampring	הצליח
פרסום תגובה ללא תוכן [PATCHED].	Tampring	הצליח
פרסום תגובה שתוכנה ארוך מ-140 תווים.	Tampring	הצליח
פרסום תגובה בזמן עבר או עתיד.	Tampring	הצליח
ביצוע HTML Injection בשדה התוכן של בקשת פרסום התגובה.	Tampring	הצליח
חשיפת מזהה הגליט בעת פרסום תגובה.	Information Disclosure	הצליח
פרסום תגובה תוך שינוי מזהה המשתמש למזהה של משתמש אחר.	Spoofing	לא הצליח
פרסום תגובה תוך שינוי מזהה המשתמש למזהה משתמש שאינו קיים.	Spoofing	לא הצליח

מחקר נק' כניסה

750	מספר הבקשה
וואו	שם הבקשה בעברית
750#{gli&er}{"user_id":68793,"user_screen_name":"lorem_ipsum","glit_id":164807}##	דוגמא אמיתית
ביצוע וואו לגליט	תפקיד הבקשה
הסבר מזהה המשתמש שם המסך של המשתמש מזהה הגליט	שם user_id user_screen_name glit_id
Wow pulish 755# approved{gli&er}{"glit_id":164807,"user_id":68793,"user_screen_name":"lorem_ipsum","id"##:14334,"date":"2026-09-25T21:12:02.857Z"}	דוגמא אמיתית לתגובה

תרחישי תקיפה לנק' כניסה

תרחישים הקשורים לפרמטר ספציפי או לעצם הבקשה

החולשה	סוג החולשה (STRIDE)	הצליח / לא הצליח
ביצוע וואו למזהה גליט שאינו קיים.	Spoofing	הצליח
ביצוע וואו לגליט של משתמש פרטי שאינו אחד מחבריו.	Tampring	הצליח
ביצוע וואו תוך שינוי שם המסך לשם קצר מחמש תווים או ריק.	Tampring	הצליח
ביצוע וואו תוך שינוי שם המסך לשם שאינו קיים במערכת.	Tampring	הצליח
ביצוע וואו פעמיים לגליט.	Tampring	הצליח
חשיפת מזהה הגליט בעת ביצוע וואו.	Information Disclosure	הצליח
ביצוע וואו תוך שינוי מזהה המשתמש למזהה של משתמש אחר.	Spoofing	לא הצליח
ביצוע וואו תוך שינוי מזהה המשתמש למזהה משתמש שאינו קיים.	Spoofing	לא הצליח

מחקר נק' כניסה

550	מספר הבקשה
פרסום גליט	שם הבקשה בעברית
550#{gli&&er}{"feed_owner_id":68793,"publisher_id":68793,"publisher_screen_name":"lorem_ipsum","publisher_avatar":"im4","background_color":"OrangeRed","date":"2026-09-26T00:19:58.903702Z","content":"lorem_ipsum","font_color":"black","id":-1}##	דוגמא אמיתית
פרסום גליט בפיד	תפקיד הבקשה
הסבר	שם
מזהה המשתמש של בעל הפיד	feed_owner_id
מזהה המשתמש של מפרסם הגליט	publisher_id
שם המסך של מפרסם הגליט	publisher_screen_name
האווטאר של מפרסם הגליט	publisher_avatar
צבע הרקע של הגליט	background_color
זמן פרסום הגליט	date
תוכן הגליט	content
צבע כיתוב הגליט	font_color
מזהה הגליט	id
555#Glit publish approved{gli&&er}{"feed_owner_id":68793,"publisher_id":68793,"publisher_screen_name":"lorem_ipsum","publisher_avatar":"im4","background_color":"OrangeRed","date":"2026-09-26T00:19:58.903702Z","content":"lorem_ipsum","font_color":"black","id":164811}	דוגמא אמיתית לתגובה

תרחישי תקיפה לנק' כניסה

תרחישים הקשורים לפרמטר ספציפי או לעצם הבקשה

החולשה	סוג החולשה (STRIDE)	הצליח / לא הצליח
פרסום גליט בפיד של משתמש פרטי שאיני אחד מחבריו.	Tampring	הצליח
פרסום גליט תוך שינוי שם המסך לשם קצר מחמש תווים או ריק בפיד של משתמש אחר.	Tampring	הצליח
פרסום גליט תוך שינוי שם המסך לשם שאינו קיים במערכת בפיד של משתמש אחר.	Tampring	הצליח
פרסום גליט ללא תוכן [PATCHED].	Tampring	הצליח
פרסום גליט שתוכנו ארוך מ-140 תווים.	Tampring	הצליח
פרסום גליט בזמן עבר או עתיד.	Tampring	הצליח
ביצוע HTML Injection בשדה התוכן של בקשת פרסום גליט.	Tampring	הצליח
פרסום גליט תוך שינוי האווטאר לאווטאר שונה מהמוגדר במשתמש.	Tampring	הצליח
פרסום גליט תוך שינוי צבע הפונט.	Tampring	הצליח
פרסום גליט תוך שינוי צבע הרקע לצבע שאינו קיים במערכת.	Tampring	הצליח
פרסום גליט תוך שינוי שם המסך לשם קצר מחמש תווים או ריק בפיד שלי.	Tampring	לא הצליח
פרסום גליט תוך שינוי שם המסך לשם שאינו קיים במערכת בפיד שלי.	Tampring	לא הצליח
פרסום גליט ללא אוטאר.	Tampring	לא הצליח
פרסום גליט ללא צבע פונט.	Tampring	לא הצליח

לא הצליח	Tampring	פרסום גליט ללא צבע רקע.
לא הצליח	Tampring	פרסום גליט בפייד של משתמש שאינו קיים.
לא הצליח	Spoofing	פרסום גליט תוך שינוי מזהה המפרסם למזהה של משתמש אחר.
לא הצליח	Spoofing	פרסום גליט תוך שינוי מזהה המפרסם למזהה לא קיים.

מחקר נק' כניסה		
150		מספר הבקשה
הרשמה		שם הבקשה בעברית
150#{gli&&er}{"registration_code":"11111","user":{"screen_name":"lorem_ipsum","avatar":"im4","description":"lorem_ipsum","privacy":"Public","id":-1,"user_name":"yona5","password":"yona5","gender":"Male","mail":"lorem_ipsum@lorem.ipsum"}}##		דוגמא אמיתית
הרשמה לאתר		תפקיד הבקשה
שם	שם	תיאור פרמטרים
קוד ההרשמה	registration_code	
שם המסך של המשתמש	screen_name	
האווטאר של המשתמש	avatar	
התיאור של המשתמש	description	
פרטיות הפרופיל של המשתמש	privacy	
מזהה המשתמש	id	
שם המשתמש	user_name	
סיסמא	password	
מין המשתמש	gender	
כתובת המייל של המשתמש	mail	
User registration 155#approved{gli&&er}{"screen_name":"lorem_ipsum","avatar":"im4","description":"lorem_ipsum","privacy":"Public","id":68815,"user_name":"yona5","password":"yona5","gender":"Male","mail":"lorem_ipsum@lorem.ipsum"}##		דוגמא אמיתית לתגובה
תרחישי תקיפה לנק' כניסה		
תרחישים הקשורים לפרמטר ספציפי או לעצם הבקשה		
החולשה	סוג החולשה (STRIDE)	הצליח / לא הצליח
ביצוע הרשמה עם קוד הרשמה קצר מ-5 תווים.	Tampring	הצליח
ביצוע הרשמה עם שם מסך קצר מ-5 תווים [PATCHED].	Tampring	הצליח
ביצוע הרשמה עם שם משתמש קצר מ-5 תווים [PATCHED].	Tampring	הצליח
ביצוע הרשמה עם כתובת מייל ריקה [PATCHED].	Tampring	הצליח
ביצוע הרשמה עם שם משתמש ריק.	Tampring	לא הצליח
ביצוע הרשמה עם שם מסך ריק.	Tampring	לא הצליח
ביצוע הרשמה עם קוד הרשמה ריק.	Tampring	לא הצליח



לא הצליח	Tampring	ביצוע הרשמה עם אוטאר ריק.
לא הצליח	Tampring	ביצוע הרשמה עם תיאור ריק.

מחקר נק' כניסה		
300	מספר הבקשה	
חיפוש	שם הבקשה בעברית	
300#{gli&&er}{"search_entry":"lorem_ipsum","search_type":"SIMPLE"}##	דוגמא אמיתית	
חיפוש משתמש לפי שם מסך	תפקיד הבקשה	
הסבר	שם	תיאור פרמטרים
ערך החיפוש	search_entry	
סוג החיפוש	search_type	
Entities search result{gli&&er}[{"screen_name":"Lorem ipsum dolor sit amet, consectetur 305# adipiscing elit. Sed do eiusmod tempor incididunt ut labore ","avatar":"im7","description":"asd","privacy":"Private","id":42982,"mail":"ssasd@gmail.com"},...]##		דוגמא אמיתית לתגובה
תרחישי תקיפה לנק' כניסה		
תרחישים הקשורים לפרמטר ספציפי או לעצם הבקשה		
החולשה	סוג החולשה (STRIDE)	הצליח / לא הצליח
ביצוע חיפוש ריק.	Tampring	הצליח
חשיפת מזהה של משתמש וכתובת המייל של משתמש בעת ביצוע חיפוש.	Information Disclosure	הצליח

מחקר נק' כניסה

מספר הבקשה		350
שם הבקשה בעברית		עדכון הגדרות
דוגמא אמיתית		350#{gli&er}{"screen_name":"lorem_ipsum","avatar":"im4","description":"lorem_ipsum","privacy":"Public","id":68793,"user_name":"json1","password":"1234","gender":"Male","mail":"lorem_ipsum@lorem.ipsum"}##
תפקיד הבקשה		עדכון הגדרות המשתמש
תיאור פרמטרים		שם
		הסבר
		שם המסך של המשתמש
		האווטאר של המשתמש
		התיאור של המשתמש
		פרטיות הפרופיל של המשתמש
		מזהה המשתמש
		שם המשתמש
		סיסמא
		מין המשתמש
		כתובת המייל של המשתמש
דוגמא אמיתית לתגובה		User setting update 355# approved{gli&er}{"screen_name":"lorem_ipsum","avatar":"im4","description":"lorem_ipsum","privacy":"Public","id":68793,"user_name":"json1","password":"1234","gender":"Male","mail":"lorem_ipsum@lorem.ipsum","date":"2026-09-26T06:10:33.743Z"}##

תרחישי תקיפה לנק' כניסה

תרחישים הקשורים לפרמטר ספציפי או לעצם הבקשה

החולשה	סוג החולשה (STRIDE)	הצליח / לא הצליח
עדכון שם המסך לשם קצר מ-5 תווים [PATCHED].	Tampring	הצליח
חשיפת שם משתמש של משתמש אחר בעת ניסיון עדכון הגדרות לפי מזהה המשתמש.	Spoofing Information Disclosure	הצליח
עדכון שם המשתמש.	Tampring	לא הצליח
עדכון הסיסמא.	Tampring	לא הצליח
עדכון כתובת המייל לכתובת מייל ריקה.	Tampring	לא הצליח
עדכון שם המסך לשם מסך ריק.	Tampring	לא הצליח
עדכון האווטאר לאווטאר ריק.	Tampring	לא הצליח
עדכון התיאור לתיאור ריק.	Tampring	לא הצליח
עדכון הגדרות של משתמש אחר.	Spoofing	לא הצליח

מחקר נק' כניסה			
720		מספר הבקשה	
ביטול לייק		שם הבקשה בעברית	
720#{gli&&er}2150325##		דוגמא אמיתית	
ביטול לייק לגליט		תפקיד הבקשה	
הסבר		שם	
מזהה הלייק		""	
Unlike publish approved{gli&&er}-{ "glit_id":164840,"user_id":68794,"id":2150325,"date":"2026-725-##09-26T06:26:58.225Z"}		דוגמא אמיתית לתגובה	
תרחישי תקיפה לנק' כניסה			
תרחישים הקשורים לפרמטר ספציפי או לעצם הבקשה			
החולשה	סוג החולשה (STRIDE)	הצליח / לא הצליח	
הסרת לייק שנעשה על ידי משתמש אחר.	Spoofing	הצליח	
	Other	לא הצליח	

מחקר נק' כניסה		
760		מספר הבקשה
ביטול וואו		שם הבקשה בעברית
760#{gli&er}14342##		דוגמא אמיתית
ביטול וואו לגליט		תפקיד הבקשה
הסבר	שם	תיאור פרמטרים
מזהה הוואו	""	
Unwow publish approved{gli&er}{\"glit_id\":164848,\"user_id\":68794,\"id\":14342,\"date\":\"2026-765#\"#09-26T06:46:41.581Z\"}		דוגמא אמיתית לתגובה
תרחישי תקיפה לנק' כניסה		
תרחישים הקשורים לפרמטר ספציפי או לעצם הבקשה		
החולשה	סוג החולשה (STRIDE)	הצליח / לא הצליח
הסרת וואו שנעשה על ידי משתמש אחר.	Spoofing	הצליח
	Other	לא הצליח
הסרת וואו עד להגעת המונה לערך שלילי.		

מחקר נק' כניסה		
200	מספר הבקשה	
התנתקות	שם הבקשה בעברית	
200#{gli&&er}68794##	דוגמא אמיתית	
התנתקות מהאתר	תפקיד הבקשה	
הסבר	שם	תיאור פרמטרים
מזהה המשתמש	""	
##User logout approved{gli&&er}205#		דוגמא אמיתית לתגובה
תרחישי תקיפה לנק' כניסה		
תרחישים הקשורים לפרמטר ספציפי או לעצם הבקשה		
החולשה	סוג החולשה (STRIDE)	הצלחה / לא הצליח
ניתוק משתמש פעמיים.	Other	לא הצליח
ניתוק משתמש מחובר אחר.	Spoofing	לא הצליח

מחקר נק' כניסה		
100	מספר הבקשה	
התחברות	שם הבקשה בעברית	
100#{gli&&er}{"user_name":"json1","password":"1234","enable_push_notifications":true}##	דוגמא אמיתית	
התחברות לאתר	תפקיד הבקשה	
הסבר	שם	תיאור פרמטרים
שם המשתמש	user_name	
סיסמא	password	
אישור קבלת התראות דחיפה	enable_push_notifications	
##Login received. Please complete ascii checksum.{gli&&er}105#		דוגמא אמיתית לתגובה
תרחישי תקיפה לנק' כניסה		
תרחישים הקשורים לפרמטר ספציפי או לעצם הבקשה		
החולשה	סוג החולשה (STRIDE)	הצלחה / לא הצליח
חשיפת סיכום הביקורת של משתמש בעת ניסיון התחברות.	Spoofing	הצלחה
התחברות עם סיסמא שגויה.	Information Disclosure	לא הצליח
	Spoofing	לא הצליח



מחקר נק' כניסה		
110		מספר הבקשה
אותנטיקציה		שם הבקשה בעברית
110#{gli&er}693##		דוגמא אמיתית
אימות זהות המשתמש בעת התחברות לאתר		תפקיד הבקשה
הסבר	שם	תיאור פרמטרים
סיכום הביקורת של המשתמש	""	
Authentication 115# approved{gli&er}{"screen_name":"lorem_ipsum","avatar":"im4","description":"lorem_ipsum","privacy":"Public","id":68793,"user_name":"json1","password":"1234","gender":"Male","mail":"lorem_ipsu ##m@lorem.ipsum","date":"2026-09-26T08:39:40.424Z"}		דוגמא אמיתית לתגובה
תרחישי תקיפה לנק' כניסה		
תרחישים הקשורים לפרמטר ספציפי או לעצם הבקשה		
החולשה	סוג החולשה (STRIDE)	הצליח / לא הצליח
אימות זהות של משתמש עם סיכום ביקורת שגוי.	Spoofing	לא הצליח